

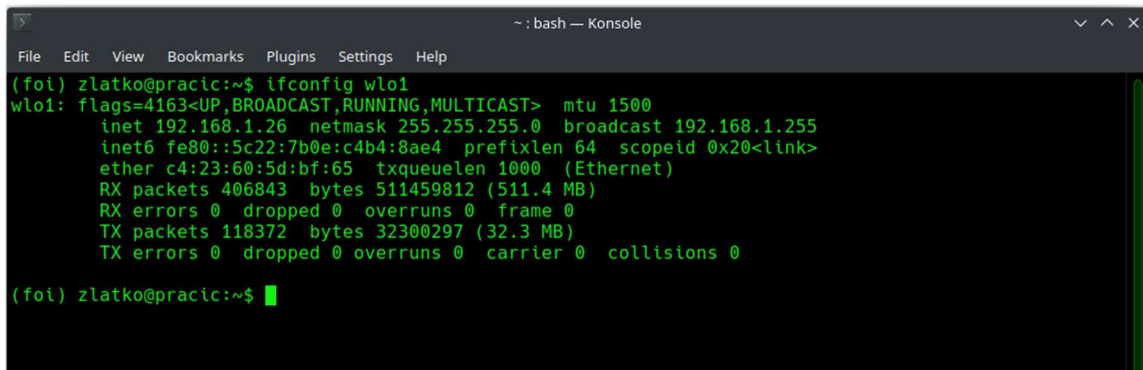
Wireshark: TLS i DTLS

I. TLS kao dio HTTPS-a

1. Za prvih 8 Ethernetovih okvira navedite tko je poslao okvir (klijent ili poslužitelj), odredite broj TLS-ovih zapisa sadržanih u tom okviru te navedite tipove TLS-ovih zapisa sadržanih u okviru. Nacrtajte vremenski dijagram razmjene TLS-ovih zapisa između klijenta i poslužitelja sa jednom strelicom za svaki TLS-ov zapis.

Kako bi se odradila treća vježba, pristupalo se stranici www.howsmyssl.com.

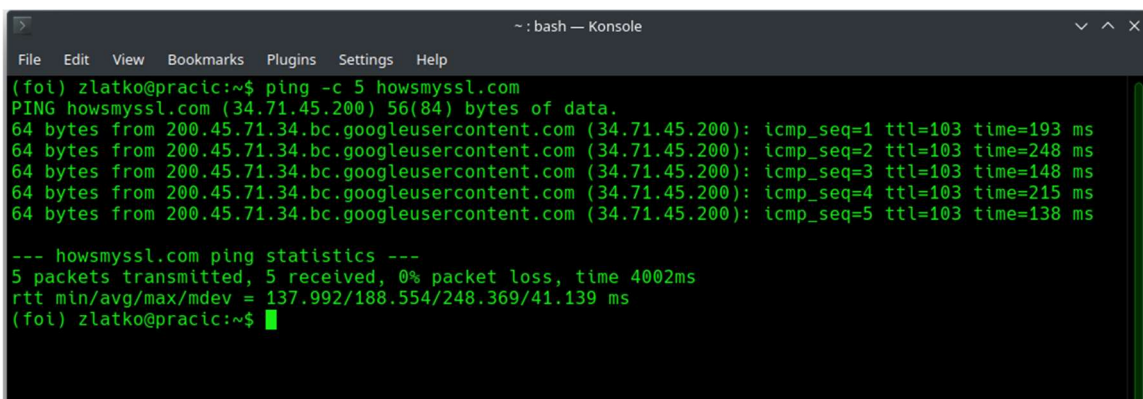
Da bi se filtrirao promet vezan uz tu stranicu bilo je potrebno pronaći IP adresu računala te IP adresu same stranice. To se odradilo u Terminalu uz pomoć komandi “ifconfig” i “ping” (Slika 1 i 2).



```
~ : bash — Konsole
File Edit View Bookmarks Plugins Settings Help
(foi) zlatko@pracic:~$ ifconfig wlo1
wlo1: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.1.26 netmask 255.255.255.0 broadcast 192.168.1.255
    inet6 fe80::5c22:7b0e:c4b4:8ae4 prefixlen 64 scopeid 0x20<link>
    ether c4:23:60:5d:bf:65 txqueuelen 1000 (Ethernet)
    RX packets 406843 bytes 511459812 (511.4 MB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 118372 bytes 32300297 (32.3 MB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

(foi) zlatko@pracic:~$
```

Slika 1 - ifconfig

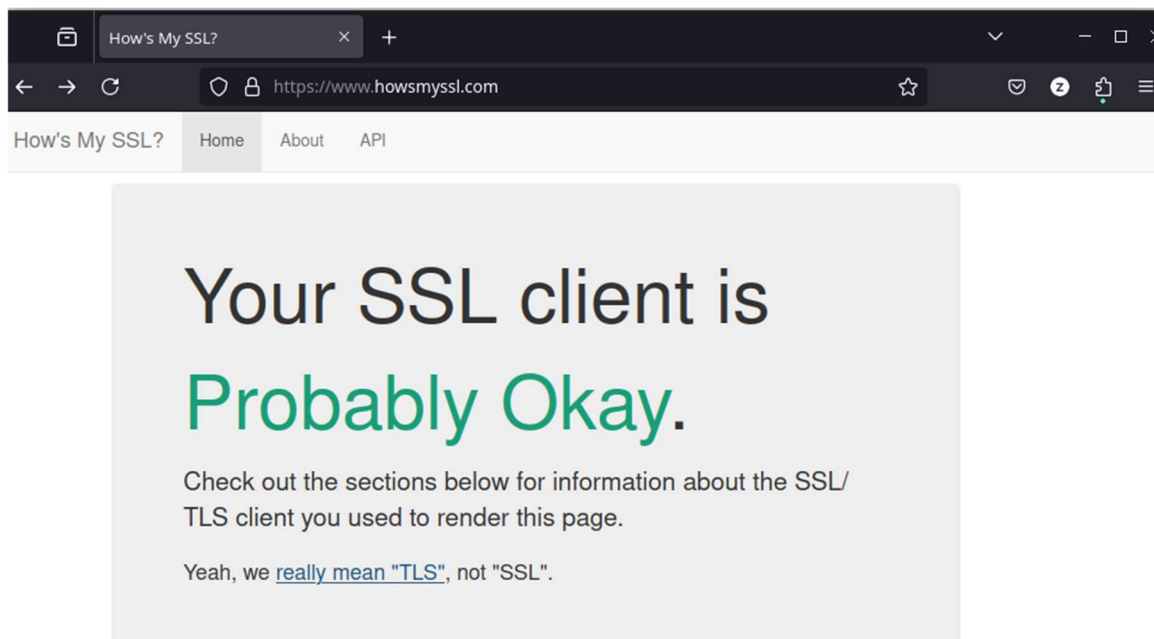


```
~ : bash — Konsole
File Edit View Bookmarks Plugins Settings Help
(foi) zlatko@pracic:~$ ping -c 5 howsmyssl.com
PING howsmyssl.com (34.71.45.200) 56(84) bytes of data.
64 bytes from 200.45.71.34.bc.googleusercontent.com (34.71.45.200): icmp_seq=1 ttl=103 time=193 ms
64 bytes from 200.45.71.34.bc.googleusercontent.com (34.71.45.200): icmp_seq=2 ttl=103 time=248 ms
64 bytes from 200.45.71.34.bc.googleusercontent.com (34.71.45.200): icmp_seq=3 ttl=103 time=148 ms
64 bytes from 200.45.71.34.bc.googleusercontent.com (34.71.45.200): icmp_seq=4 ttl=103 time=215 ms
64 bytes from 200.45.71.34.bc.googleusercontent.com (34.71.45.200): icmp_seq=5 ttl=103 time=138 ms

--- howsmyssl.com ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4002ms
rtt min/avg/max/mdev = 137.992/188.554/248.369/41.139 ms
(foi) zlatko@pracic:~$
```

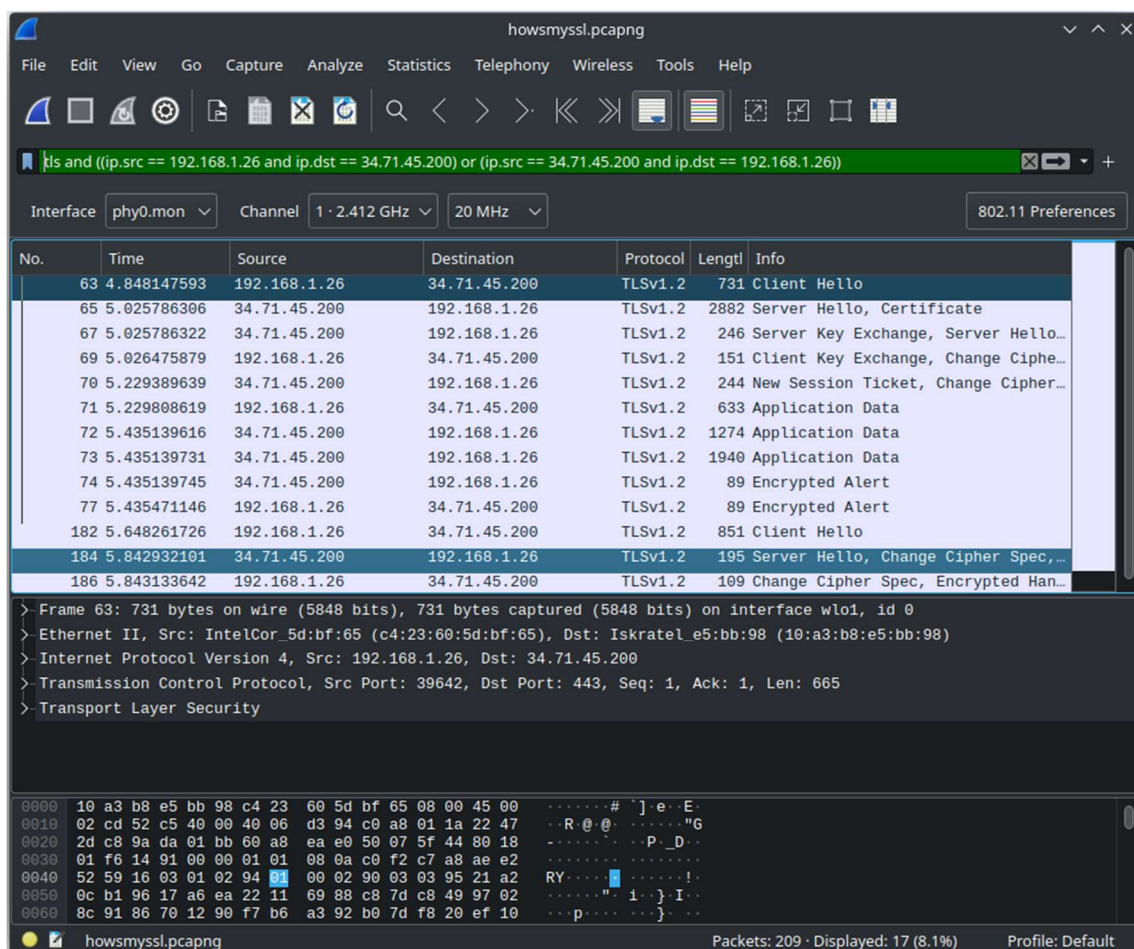
Slika 2 - ping

Nakon pokretanja Wireshark aplikacije, da bi se stranica učitala iz početka, u pregledniku se uz pomoć kombinacije tipki Ctrl + F5 sadržaj nanovo učitao (Slika 3).



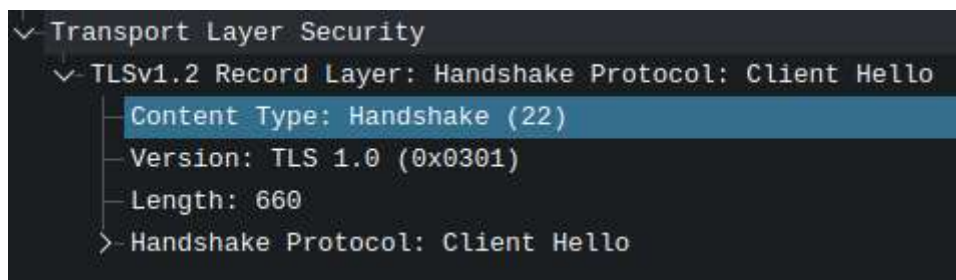
Slika 3 - web stranica

Promet vezan uz učitavanje navedene stranice te uz TLS protokol se dobio uz pomoć filtra `tls and ((ip.src == 192.168.1.26 and ip.dst == 34.71.45.200) or (ip.src == 34.71.45.200 and ip.dst == 192.168.1.26))` (Slika 4).



Slika 4 - Wireshark

Prvi paket je poslao je **klijent** (Source = 192.168.1.26). U **prvom** okviru nalazi se **samo jedan TLS zapis**. Radi se o **TLS tipu zapisa ClientHello** kojim započinje sam proces **rukovanja**, odnosno Handshaking (Slika 5).



Slika 5 - prvi okvir

Drugi paket je poslao je **poslužitelj** (Source = 34.71.45.200). U **drugom** okviru nalaze se **dva TLS zapisi**. Radi se o **TLS tipu zapisa ServerHello** kojim se nastavlja proces **rukovanja**, odnosno Handshaking. Drugi TLS zapis je **Certificate** (Slika 6).



Slika 6 - drugi okvir

Treći paket je poslao je **poslužitelj** (Source = 34.71.45.200). U **trećem** okviru nalaze se **tri TLS zapisa**. Radi se o **TLS tipovima zapisa Server Key Exchange i ServerHello Done** (Slika 7).



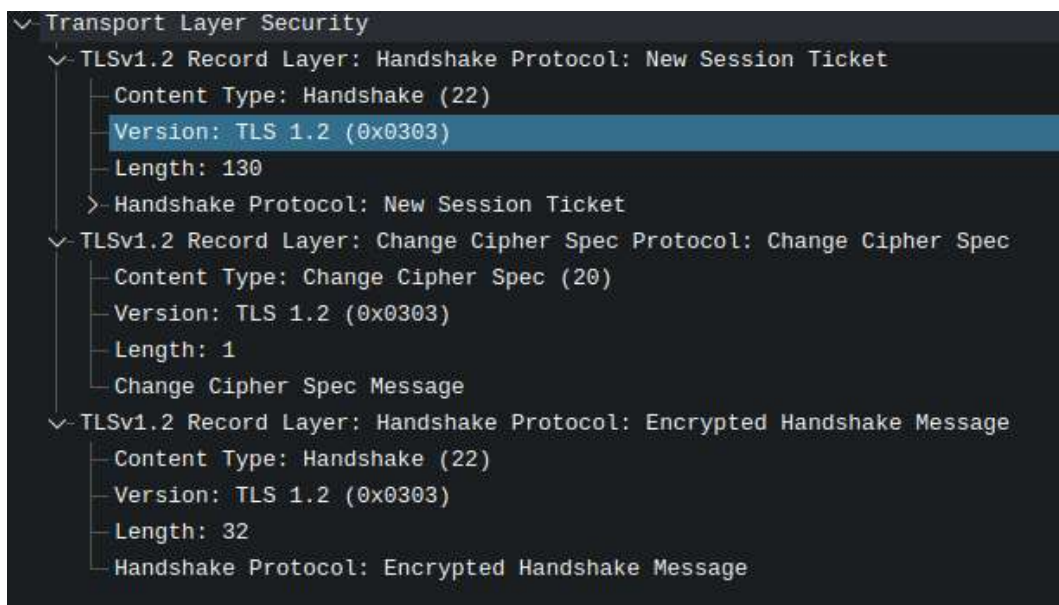
Slika 7 - treći okvir

Četvrti paket je poslao je **klijent klijent** (Source = 192.168.1.26). U četvrtom okviru nalaze se **tri TLS zapisa**. Radi se o **TLS tipovima zapisa Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message** (Slika 8).



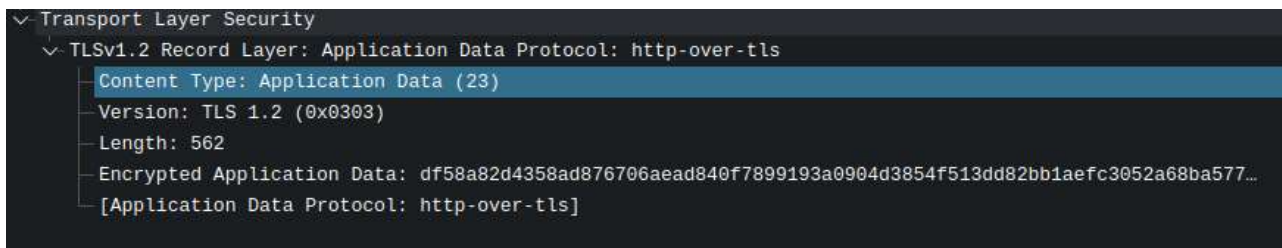
Slika 8 - četvrti okvir

Peti paket je poslao **poslužitelj** (Source = 34.71.45.200). U petom okviru nalaze se **tri TLS zapisa**. Radi se o **TLS tipovima zapisa New Session Ticket, Change Cipher Spec, Encrypted Handshake Message** (Slika 9).



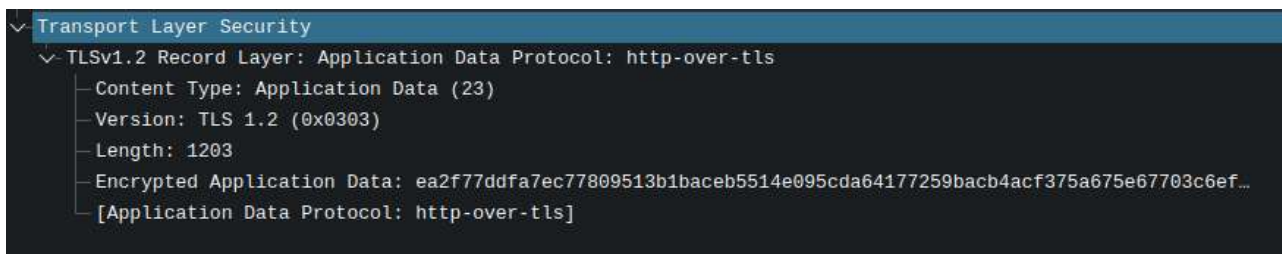
Slika 9 – peti okvir

Šesti paket je poslao je **klijent** (Source = 192.168.1.26). U **šestom** okviru nalazi se **jedan TLS zapis**. Radi se o **TLS tipu zapisa Application Data** (Slika 10).



Slika 10 – šesti okvir

Sedmi paket je poslao je **poslužitelj** (Source = 34.71.45.200). U **sedmom** okviru nalazi se **jedan TLS zapis**. Radi se o **TLS tipu zapisa Application Data** (Slika 11).



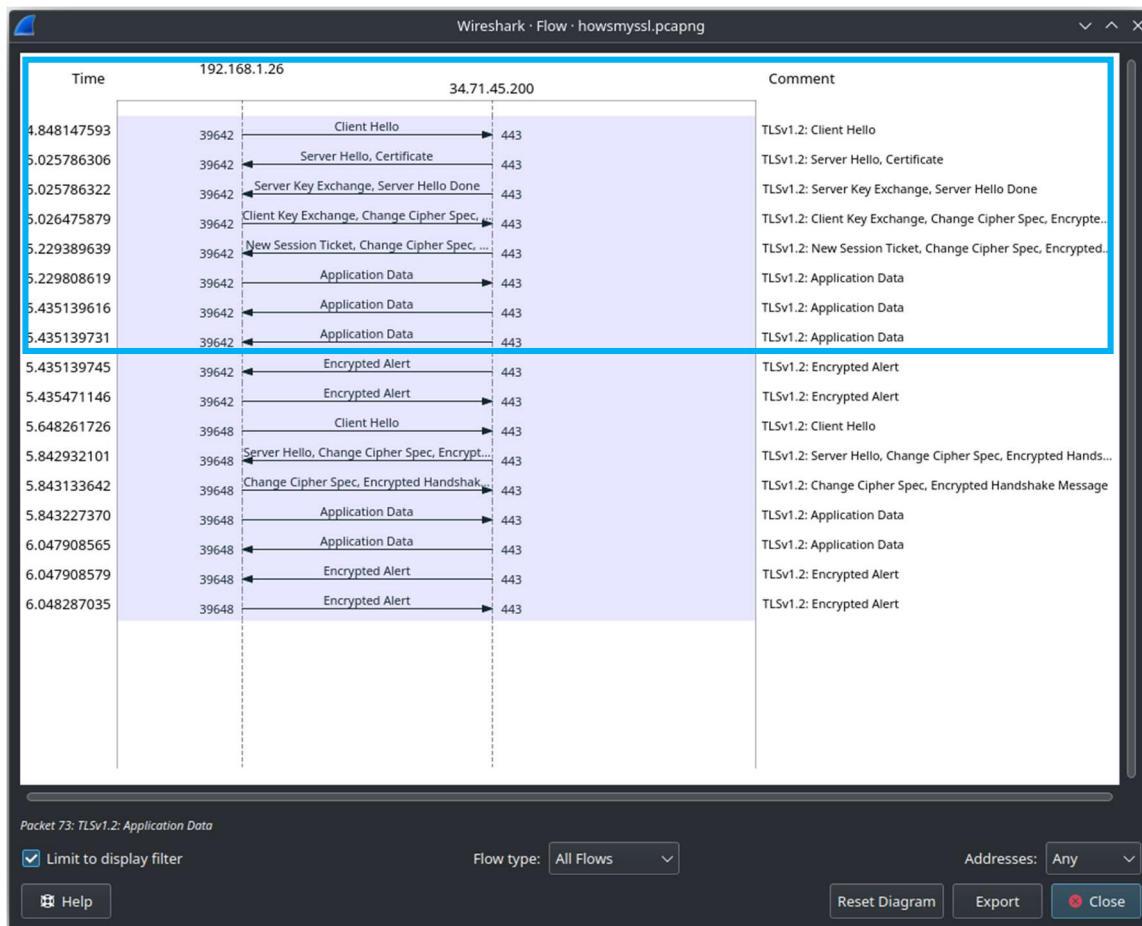
Slika 11 – sedmi okvir

Osmi paket je poslao je **poslužitelj** (Source = 34.71.45.200). U **osmom** okviru nalazi se **jedan TLS zapis**. Radi se o **TLS tipu zapisa Application Data** (Slika 12).



Slika 12 – osmi okvir

Na Slici 13 je vidljiv vremenski dijagram razmjene TLS-ovih zapisa između klijenta i poslužitelja. U plavom okviru je prvih osam TLS paketa.



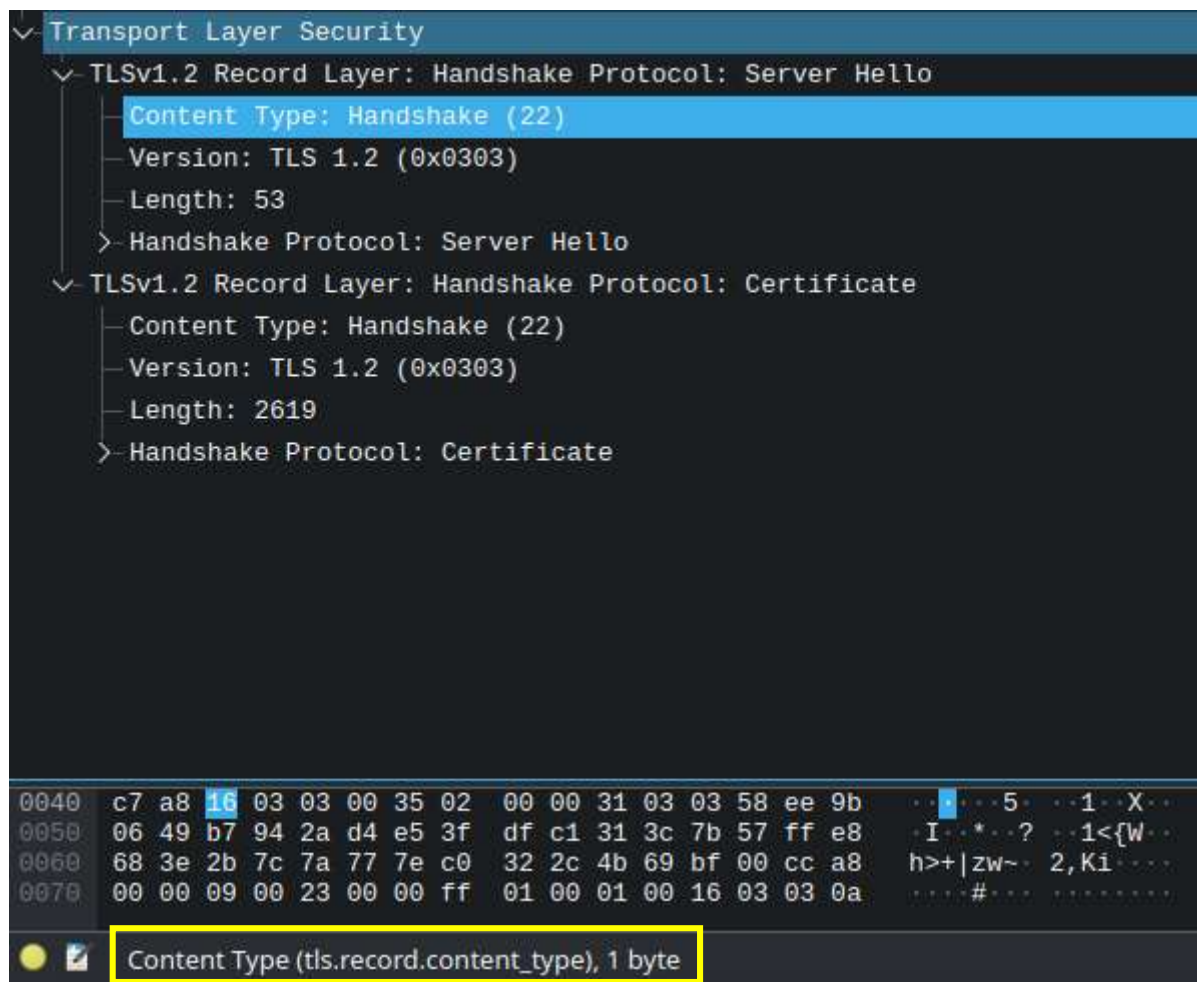
Slika 13 – vremenski dijagram razmjene TLS zapisa

2. Svaki TLS-ov zapis započinje s tri polja (u kojima mogu biti zapisane različite vrijednosti). Jedno od tih polja je content type (“tip sadržaja”) i zauzima jedan bajt. Navedite sva tri polja i njihove duljine.

Svaki TLS zapis počinje sa sljedećim poljima (navedene su i dužine):

1. **Content Type** (“Tip sadržaja”) – navedeno polje zauzima **1 bajt** unutar TLS zapisa.
2. **Version** (“Verzija”) – navedeno polje zauzima **2 bajta** unutar TLS zapisa.
3. **Length** (“Duljina”) – navedeno polje zauzima **2 bajta** unutar TLS zapisa.

Na Slici 14 je odabran jedan okvir i iz njega je vidljivo koja su zajednička polja, a na dnu je žutim okvirom označena duljina polja.



Slika 14 – TLS zapis i duljina polja

Zapis *ClientHello*:

3. Proširite zapis *ClientHello*. (Ako snimka sadrži više zapisa tipa *ClientHello*, tada proširite pogled za prvi okvir koji sadrži taj zapis.) Koja je vrijednost polja content type?

Content Type: Handshake (22)

4. Sadrži li zapis tipa *ClientHello* nonce (poznat i kao “challenge” odn. “izazov”)? Ako sadrži koja je njegova vrijednost (zapišite u heksadekadskom obliku)?

Random: 9521a20cb19617a6ea22116988c87dc84997028c9186701290f7b6a392b07df8

5. Oglašava li klijent u zapisu *ClientHello* kriptografske skupove koje podržava? Ako da, tada za prvi kriptografski skup u listi zapišite koji se algoritam asimetričnog kriptiranja koristi, koji algoritam simetričnog kriptiranja te koji algoritam za sigurnosnu funkciju sažimanja?

Cipher Suites (17 suites)

Cipher Suite: TLS_AES_128_GCM_SHA256 (0x1301)

Cipher Suite: TLS_CHACHA20_POLY1305_SHA256 (0x1303)

Cipher Suite: TLS_AES_256_GCM_SHA384 (0x1302)

Cipher Suite: TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256 (0xc02b)

Cipher Suite: TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)
 Cipher Suite: TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256 (0xcca9)
 Cipher Suite: TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (0xcca8)
 Cipher Suite: TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 (0xc02c)
 Cipher Suite: TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc030)
 Cipher Suite: TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA (0xc00a)
 Cipher Suite: TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA (0xc009)
 Cipher Suite: TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013)
 Cipher Suite: TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)
 Cipher Suite: TLS_RSA_WITH_AES_128_GCM_SHA256 (0x009c)
 Cipher Suite: TLS_RSA_WITH_AES_256_GCM_SHA384 (0x009d)
 Cipher Suite: TLS_RSA_WITH_AES_128_CBC_SHA (0x002f)
 Cipher Suite: TLS_RSA_WITH_AES_256_CBC_SHA (0x0035)

Označeni kriptografski skup u listi koristi sljedeće algoritme:

1. **simetrični algoritam – AES 128**
2. **algoritam za kriptiranje toka podataka – GCM (Galois Counter Mode)**
3. **algoritam za sigurnosnu funkciju sažimanja – SHA256**

Zapis ServerHello:

6. Pronađite zapis ServerHello. Sadrži li ovaj zapis odabrani kriptografski skup? Koje se algoritmi koriste u odabranom kriptografskom skupu?

Cipher Suite: TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (0xcca8)

Asimetrični kriptografski algoritam: ECDHE_RSA (Elliptic Curve Diffie-Hellman Ephemeral s RSA autentifikacijom). ECDHE (Elliptic Curve Diffie-Hellman Ephemeral): Koristi se za razmjenu ključeva. RSA: Koristi se za autentifikaciju.

Simetrični kriptografski algoritam: CHACHA20: Simetrični ključni algoritam za enkripciju podataka.

Algoritam za sigurnosnu funkciju sažimanja (hash funkcija): POLY1305: Algoritam za autentifikaciju poruka, koji se često koristi zajedno s ChaCha20 za autentifikaciju šifriranih podataka.

7. Sadrži li ovaj zapis nonce? Ako sadrži, koliko je bajtova dugačak? Koja je svrha korištenja klijentskog i poslužiteljskog broja nonce u TLS-u?

Sadrži i dugačak je 32 bajta. Klijentski i poslužiteljski nonce brojevi u TLS-u osiguravaju jedinstvenost i sigurnost svake sesije, povećavajući entropiju za generiranje kriptografskih ključeva i time omogućuju **sprečavanje napada snimanjem i ponavljanjem poruka**.

Random: 58ee9b0649b7942ad4e53fdcf1313c7b57ffe8683e2b7c7a777ec0322c4b69bf

8. Sadrži li ovaj zapis identifikator sjednice (session ID)? Koja je svrha polja session ID?

Session ID Length: 0

Za razliku od Session ID kod Client Hello, Server Hello nema Session ID.

Svrha polja Session ID u TLS-u je omogućiti ponovno korištenje prethodno uspostavljenih sesija, čime se smanjuje vrijeme i resursi potrebni za uspostavljanje novih veza kroz optimizaciju performansi i smanjenje opterećenja mreže.

9. Sadrži li ovaj zapis certifikat ili se certifikat nalazi u odvojenom zapisu. Stane li certifikat u jedan Ethernetov okvir?

TLS certifikat se šalje u odvojenom zapisu (Certificate poruci) nakon ServerHello poruke. Certifikat obično ne stane u jedan Ethernet okvir zbog svoje veličine, pa se fragmentira i prenosi u više okvira.

Zapis Client Key Exchange

10. Pronađite zapis client key exchange. Sadrži li ovaj zapis pred-glavu tajnu? Za što se ta tajna koristi? Je li ta tajna kriptiranja? Ako je, kako je kriptirana? Koliko je velika kriptirana tajna?

Klijent šalje svoj Diffie-Hellman javni ključ (32 bajta) serveru u poruci ClientKeyExchange. Zajedno sa serverovim javnim ključem, ova dva javna ključa se koriste za izračunavanje zajedničkog ključa, koji se zatim koristi za generiranje ključeva za simetričnu enkripciju sesije.

Zapisi Change Cipher Spec (poslan od klijenta) i Encrypted Handshake:

11. Koja je svrha zapisa Change Cipher Spec? Koliko je velik taj zapis u snimci mrežnog prometa?

Svrha zapisa Change Cipher Spec je prijelazu s nekodiranog na kodirani način komunikacije u TLS protokolu. Ona osigurava da su klijent i poslužitelj sinkronizirani u pogledu korištenja dogovorenih kriptografskih parametara za zaštitu podataka tijekom sesije. Zapis je veličine 6 bajta.

12. Što je kriptirano u zapisu encrypted handshake? Kako?

U zapisu „encrypted handshake“ šifriran je MAC svih poruka razmijenjenih tijekom rukovanja. Ovo sprječava napade čovjeka u sredini jer klijent i poslužitelj provjeravaju jesu li primili sve poruke koje je druga strana poslala. Za šifriranje se koristi HMAC-SHA256 funkcija sažimanja i zajednički tajni ključ.

13. Šalje li i poslužitelj zapise change cipher i encrypted handshake klijentu? Kako se ti zapisi razlikuju od zapisa koje je poslao klijent?

Poslužitelj također šalje poruke „change cipher“ „encrypted handshake“ klijentu. Poruka „change cipher“ potvrđuje da će se koristiti prethodno dogovoreni ključevi. U poruci „encrypted handshake“, poslužitelj šalje klijentu MAC svih poruka iz rukovanja kako bi spriječio napad čovjeka u sredini.

Tip sadržaja Application Dana

14. Kako su aplikacijski podaci kriptirani? Sadrže li zapisi s kriptiranim aplikacijskim podacima i MAC? Razlikuje li Wireshark kriptirane aplikacijske podatke i MAC?

Aplikacijski podaci u TLS-u kriptiraju se simetričnim ključem dogovorenim tijekom TLS rukovanja, najčešće koristeći algoritme poput AES-a. TLS zapisi obično sadrže i kriptirane aplikacijske podatke i MAC za provjeru integriteta. Wireshark ne može razlikovati kriptirane podatke i MAC bez pristupa ključevima sesije. S ključevima, Wireshark može dekriptirati promet i odvojeno prikazati podatke i MAC.

15. Komentirajte i objasnite bilo što drugo zanimljivo što ste pronašli u snimci TLS-ove sjednice.

Dodatni odgovori:

A. Koju verziju protokola ste analizirali?

Analiziran je protokol TLS v1.2

B. Koja se je metoda koristila za razmjenu ključeva (RSA, DH, ...)

Metoda korištena za razmjenu ključeva je **Elliptic Curve Diffie-Hellman Ephemeral (ECDHE)**. ECDHE omogućava klijentu i serveru da sigurno uspostave zajednički tajni ključ koristeći eliptičke krivulje, što pruža visoku razinu sigurnosti i *perfect forward secrecy*. U ovom slučaju, korištena je imenovana krivulja x25519, a autentičnost razmjene ključeva osigurana je RSA potpisom s SHA-256 (rsa_pkcs1_sha256).

C. Koji asimetrični algoritam se koristi u certifikatu (ako certifikat nije kriptiran – ovisno o verziji TLS-a)? Ako je, onda tu situaciju prokomentirati!

Asimetrični algoritam koji se koristi u certifikatima za www.howsmyssl.com i R10 je RSA (Rivest-Shamir-Adleman), što je naznačeno pod `subjectPublicKeyInfo`.

D. Koji se simetrični algoritam koristi za kriptiranje podataka?

Iz snimljenog prometa može se zaključiti kako se za simetrični algoritam za kriptiranje podataka koristi TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (0xcca8). Iz toga proizilazi kako se za simetrično kriptiranje podataka koristi ChaCha20-Poly1305. ChaCha20 je stream cipher (algoritam za šifriranje toka podataka) koji se koristi za enkripciju, dok Poly1305 služi kao autentifikacijski tag.

E. Radi li se o običnom načinu uspostavljanja sjednice/razgovora TLS-a ili o 0-RTT varijanti? Objasniti odgovor.

Ovo je standardno TLS 1.2 rukovanje koje zahtijeva puni round-trip između klijenta i servera prije slanja aplikacijskih podataka. 0-RTT bi omogućio slanje podataka odmah u prvom klijentskom hello, što ovdje nije slučaj.

II. DTLS i čitanje kriptiranog sadržaja

Usporedba DTLS-a i TLS koji je namijenjen za TCP

16. Proučiti poruke koje se razmjenjuju u fazi rukovanja i usporedite sa fazom rukovanja iz prvog dijela vježbe gdje ste analizirali TLS u službi HTTPS-a. Ima li DTLS neka dodatna polja u odnosu na TLS? Zašto? Čemu služe ta polja? Zabilježite svoja zapažanja.

Poruke u fazi rukovanja DTLS-a razlikuju se od onih u TLS-u zbog dodatnih polja koja su prisutna. Ova dodatna polja (epoch i sequence_number) su bitna zbog sigurnosnih zahtjeva UDP transporta. UDP paketi mogu biti izgubljeni ili stići u pogrešnom redoslijedu, stoga polje epoch se automatski povećava za 1 svaki put kada se šalje ChangeCipherSpec poruka. To osigurava jasnoću o trenutnim sigurnosnim parametrima. Polje sequence_number označava redni broj svake poruke i koristi se za sprečavanje napada snimanjem i ponavljanjem paketa.

17. Jesu li sve poruke koje šalje poslužitelj stigle u pravom redoslijedu? Kako ste to provjerili?

Poruke poslane od strane poslužitelja primljene su u ispravnom redoslijedu. Za provjeru ove činjenice, trebamo pregledati polje sequence number. Ovo polje sadrži redni broj poslane poruke koji se automatski povećava za 1 svaki put kada se poruka šalje.

18. Pogledajte možete li otkriti sadržaj poruka koje klijent šalje poslužitelju? Zašto?

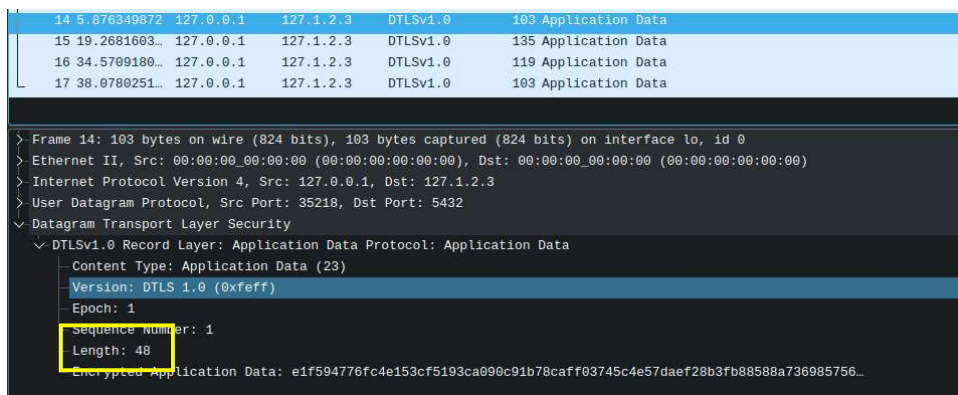
Sadržaj poruka koje klijent šalje poslužitelju nije moguće otkriti jer je taj sadržaj kriptiran simetričnim algoritmom korištenjem tajnog AES ključa.

19. Koliko je bajtova velika 1., 2., 3. i 4. aplikacijska poruka u kriptiranom obliku?

Veličina klijentskih poruka kriptiranog sadržaja:

1. poruka – 48 bajta
2. poruka – 80 bajta
3. poruka - 64 bajta
4. poruka - 48 bajta

Informacija se može pronaći unutar polja **Length**. Za prvu klijentsku aplikacijsku poruku veličina aplikacijske poruke se može vidjeti na Slici 15 (u žutom okviru).



Slika 15 – veličina aplikacijske poruke

Otkrivanje sadržaja kriptiranih poruka koje klijent šalje poslužitelju.

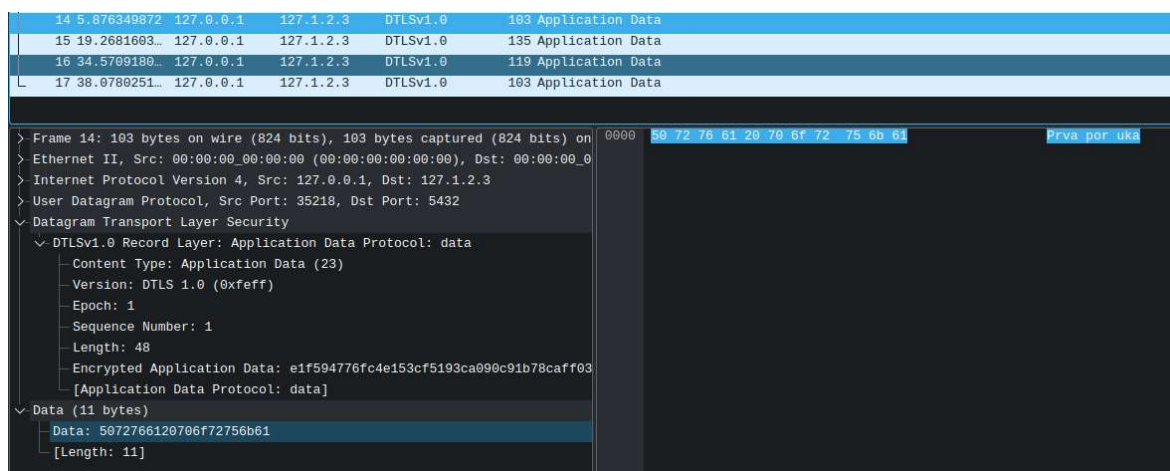
20. Očitajte sadržaj dekriptiranih poruka koje je klijent poslao poslužitelju. Zabilježite sadržaj za sve 4 razmijenjene tekstualne poruke.

Prva poruka (Slika 16)

Druga je poruka ipak nesto duza

Pozdrav prije kraja!

exit



Slika 16 - dekriptirana prva poruka